Basic of NMAP

By: Shamsher khan

What's NMAP ?

-> NMAP is a mapping or a footprinting tool.

-> It is used for network exploration.

-> NMAP collects information about target host.

-> Target can be specified by IP Adress or Domain Name.

-> command : nmap 192.168.10.1 or nmap www.google.com

What's NMAP ?

-> Host / Port / Service Discovery

-> OS Version Detection

-> Service Version Detection

-> Vulnerability and Exploit detection using NSE

-> Firewall and spoofing evasions.

Target Specification

SWITCH	EXAMPLE	DESCRIPTION
	nmap 192.168.1.1	Scan a single IP
	nmap 192.168.1.1 192.168.2.1	Scan specific IPs
	nmap 192.168.1.1-254	Scan a range
	nmap scanme.nmap.org	Scan a domain
	nmap 192.168.1.0/24	Scan using CIDR notation
-iL	nmap -iL targets.txt	Scan targets from a file
-iR	nmap -iR 100	Scan 100 random hosts
–exclude	nmap –exclude 192.168.1.1	Exclude listed hosts



We Need dummy Server for Practical so watch this and setup

https://youtu.be/npPn_x2QaeM?si=0wS2i11fvny8uIc2

Scan Techniques

SWITCH	EXAMPLE	DESCRIPTION
-sS	nmap 192.168.1.1 -sS	TCP SYN port scan (Default)
-sT	nmap 192.168.1.1 -sT	TCP connect port scan (Default without root privilege)
-sU	nmap 192.168.1.1 -sU	UDP port scan
-sA	nmap 192.168.1.1 -sA	TCP ACK port scan
-sW	nmap 192.168.1.1 -sW	TCP Window port scan
-sM	nmap 192.168.1.1 -sM	TCP Maimon port scan

Port Specification

SWITCH	EXAMPLE	DESCRIPTION
-p	nmap 192.168.1.1 -p 21	Port scan for port x
-p	nmap 192.168.1.1 -p 21-100	Port range
-p	nmap 192.168.1.1 -p U:53,T:21-25,80	Port scan multiple TCP and UDP ports
-p	nmap 192.168.1.1 -p-	Port scan all ports
-p	nmap 192.168.1.1 -p http,https	Port scan from service name
-F	nmap 192.168.1.1 -F	Fast port scan (100 ports)
–top-ports	nmap 192.168.1.1 –top-ports 2000	Port scan the top x ports
-p-65535	nmap 192.168.1.1 -p-65535	Leaving off initial port in range makes the scan start at port 1
-p0-	nmap 192.168.1.1 -p0-	Leaving off end port in range makes the scan go through to port 65535

Port Scanning

-> as we have found online hosts .. our next step will be targeting ports of active hosts.

-> there are 65,535 ports

-> nmap by default scans 1000 ports

-> nmap recognizes ports in 6 states.

Open: This indicates that an application is listening for connections on this port.

Closed: This indicates that the probes were received but there is no application listening on this port.

Filtered: This indicates that the probes were not received and the state could not be established. It also indicates that the probes are being dropped by some kind of filtering.

Unfiltered: This indicates that the probes were received but a state could not be established.

Open/Filtered: This indicates that the port was filtered or open but Nmap couldn’t establish the state.

Closed/Filtered: This indicates that the port was filtered or closed but Nmap couldn’t establish the state.

NMAP Script Engine

->The Nmap Scripting Engine (NSE) is one of Nmap's most powerful and flexible features.

-> It allows users to write (and share) simple scripts (using the Lua programming language) to automate a wide variety of networking tasks.

-> NMAP also comes with premade scripts

->NSE can even be used for vulnerability exploitation

What's a script ?

-> a script is basically a predefined code written using Lua Programming Language

-> this predefined code helps in gathering more information about services running at the ports.

List of scripts

-> for different services we have different list of scripts available.

-> we can list scripts available for a particular service using grep command.

```
ls /usr/share/nmap/scripts | grep “service_name”
```

-> for example

We can list scripts available for http service

```
ls  /usr/share/nmap/scripts | grep http
```

Script Scanning

-> default script scanning : for different services default scripts are set

-> when default script is run , nmap scan default scripts of services running at ports.

```
nmap -sC scanme.nmap.org
```

nmap –sC meta –p 21
Here –sC will automatically use all ftp related script in background

nmap –sC meta –p 22

Script Scannning

nmap --script=”script_name” 192.168.10.1

-> example

nmap --script=http-brute.nse scanme.nmap.org

//multiple scripts

nmap -script=http-traceroute.nse,http-brute.nse scanme.nmap.org

Interesting Scripts

```
# nmap --script http-enum metasploitable2

# nmap --script dns-brute www.google.com

# nmap --script whois-domain www.vulnweb.com

# nmap --script http-methods metasploitable2

# nmap --script banner metasploitable2

# nmap --script http-sitemap-generator metasploitable2

# nmap –script=mysql-info.nse metasploitable2

# nmap –script=ftp-vsftpd-backdoor metasploitable2
```

There are four types of NSE scripts

- **Pre-rule scripts** :- Scripts that run before any of Nmap's scan operations, they are executed when Nmap hasn't gathered any information about a target yet

- **Host scripts** :- Scripts executed after Nmap has performed normal operations such as host discovery, port scanning, version detection, and OS detection against a target host.

- **Service scripts** :- Scripts run against specific services listening on a target host

- **Post-rule scripts** :- Scripts run after Nmap has scanned all of its target hosts

IP Fragment (Divide tcp packet in many parts)

#nmap -f 192.168.43.23

#nmap -D Zombbi.txt target

nmap -D RND targetMachinIP (Decoys) (RND work as automatic random ip itself)

#nmap -D RND target

IDEL SCAN

#nmap -sI zombie IP Target IP

Nmap Scripting Engine (NSE Capabilities)

Version detection nmap -sV by default or using one so user --script

pptp-version (p2p turnal protocal)

stun-version (secure turnal

skypev2-version (skype)

Network discovery

http-headers

http-enum

http-title

ms-sql-info (microsoft sql server infro)

Vulnerability detection

ssl-heartbleed

http-csrf

smtp-vuln-cve2011-1720

Backdoor detection

ftp-proftpd-backdoor

irc-unrealircd-backdoor

Vulnerability exploitation (many script have on internet)

jdwp-exec (java remote debuging port)

http-stored-xss

Update NSE Database

#nmap --script-updatedb

Multiple script running

nmap -p 80 --script http-headers,http-chrono

Using args

nmap -p 23 --script telnet-brute --script-args userdb=user.lst,passdb=pass.lst tagetIP

NSE documentations on nmap.org

Script Categories

auth,discovery,fuzzer,safe,broadcast,dos,intrusive,version,brute,exploit,malware,vuln, default,external

for documantion http://nmap.org/nsedoc

OUTPUT

-> we can save our scan results in an output file.

-> nmap -oN file_name 192.168.10.1

Outputs to given file name.

-> nmap -oX file_name 192.168.10.1

-> XML Output to given file name.